CVEs más relevantes de la semana

Del 17/10/2026 al 24/10/2026

Porque el primer paso para defender es conocer las amenazas.



CVE-2026-12665

Descripción: IBM MQ could allow a remote attacker to execute arbitrary code due to a stack buffer overflow when processing TLS certificates with malformed distinguished names during channel connection establishment.

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-121

Tecnología: No especificado

Publicado el: 2026-10-19

CVE-2026-109444

Descripción: OpenSRE through 0.1.2026.10.19 contains an approval gate bypass vulnerability that allows attackers to execute shell_run commands without confirmation because the headless presenter's execution_allowed() always returns True. Attackers can inject instructions into alerts or Slack messages triaged by the agent to run commands on the host and exfiltrate LLM, Slack and cloud credentials.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-862

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-77930

Descripción: EvoScientist 0.1.0 before 0.2.5 contains an approval bypass vulnerability that allows attackers to run host shell commands by delegating them to async sub-agents lacking an interrupt_on gate. Attackers can plant instructions in ingested content such as fetched web pages, so the agent calls start_async_task and runs commands with user privileges and environment secrets.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-862

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-28763

Descripción: A stack-based buffer overflow vulnerability exists in the boa formMapDelDevice hostname functionality of X2000R (version(s): TOTOLINK-X2000R-Gh-V1.0.0-B20250421.1327). A specially crafted HTTP request can lead to arbitrary code execution. An attacker can make an authenticated HTTP request to trigger this vulnerability.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-121

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-33568

Descripción: A OS command injection vulnerability exists in the boa formMapDelDevice macstr functionality of X2000R (version(s): TOTOLINK-X2000R-Gh-V1.0.0-B20250421.1327). A specially crafted HTTP request can lead to arbitrary code execution. An attacker can make an authenticated HTTP request to trigger this vulnerability.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-40615

Descripción: A stack-based buffer overflow vulnerability exists in the boa formParentControl deviceName functionality of X2000R (version(s): TOTOLINK-X2000R-Gh-V1.0.0-B20250421.1327). A specially crafted HTTP request can lead to arbitrary code execution. An attacker can make an authenticated HTTP request to trigger this vulnerability.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-121

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-40627

Descripción: An os command injection vulnerability exists in the boa formWsc targetAPSsid functionality of Totolink X2000R TOTOLINK-X2000R-Gh-V1.0.0-B20250421.1327. A specially crafted HTTP request can lead to arbitrary code execution. An attacker can make an authenticated HTTP request to trigger this vulnerability.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-41222

Descripción: A stack-based buffer overflow vulnerability exists in the boa formParentControl url functionality of X2000R (version(s): TOTOLINK-X2000R-Gh-V1.0.0-B20250421.1327). A specially crafted HTTP request can lead to arbitrary code execution. An attacker can make an authenticated HTTP request to trigger this vulnerability.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-121

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-41223

Descripción: A stack-based buffer overflow vulnerability exists in the boa formMapDelDevice macstr functionality of X2000R (version(s): TOTOLINK-X2000R-Gh-V1.0.0-B20250421.1327). A specially crafted HTTP request can lead to arbitrary code execution. An attacker can make an authenticated HTTP request to trigger this vulnerability.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-121

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-42019

Descripción: Multiple stack-based buffer overflow vulnerabilities exist in the boa formIpv6Setup pppoe functionality of Totolink X2000R TOTOLINK-X2000R-Gh-V1.0.0-B20250421.1327. A specially crafted HTTP request can lead to arbitrary code execution. An attacker can make an authenticated HTTP request to trigger these vulnerabilities. This vulnerability concerns the pppoe_dns1 parameter.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-121

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-42020

Descripción: Multiple stack-based buffer overflow vulnerabilities exist in the boa formIpv6Setup pppoe functionality of Totolink X2000R TOTOLINK-X2000R-Gh-V1.0.0-B20250421.1327. A specially crafted HTTP request can lead to arbitrary code execution. An attacker can make an authenticated HTTP request to trigger these vulnerabilities. This vulnerability concerns the pppoe_dns2 parameter.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-121

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-9659

Descripción: Multiple exploitable stack-based buffer overflow vulnerabilities exist in the boa formFilter functionality of X2000R (version(s): TOTOLINK-X2000R-Gh-V1.0.0-B20250421.1327). A specially crafted HTTP request can lead to arbitrary code execution. An attacker can make an authenticated HTTP request to trigger these vulnerabilities. This vulnerability deals with the vpnUser parameter.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-121

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-101446

Descripción: Vulnerability in the Siebel CRM Cloud Applications product of Oracle Siebel CRM (component: Siebel Cloud Manager). Supported versions that are affected are 17.0-26.9. Easily exploitable vulnerability allows low privileged attacker with network access via HTTP to compromise Siebel CRM Cloud Applications. While the vulnerability is in Siebel CRM Cloud Applications, attacks may significantly imp...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: N/A

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-101501

Descripción: Vulnerability in Oracle Trusted Answer Search (component: PLSQL package). The supported version that is affected is 26.1. Easily exploitable vulnerability allows low privileged attacker with network access via Oracle Net to compromise Oracle Trusted Answer Search. While the vulnerability is in Oracle Trusted Answer Search, attacks may significantly impact additional products (scope change). ...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:L/I:H/A:H

Tipo: N/A

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-101503

Descripción: Vulnerability in Oracle Trusted Answer Search (component: PLSQL package). The supported version that is affected is 26.1. Easily exploitable vulnerability allows low privileged attacker with network access via Oracle Net to compromise Oracle Trusted Answer Search. While the vulnerability is in Oracle Trusted Answer Search, attacks may significantly impact additional products (scope change). ...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: N/A

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-101528

Descripción: Vulnerability in the Oracle Enterprise Manager for Oracle Database product of Oracle Enterprise Manager (component: Data Guard Management). Supported versions that are affected are 13.5 and 24.1. Easily exploitable vulnerability allows low privileged attacker with network access via HTTP to compromise Oracle Enterprise Manager for Oracle Database. While the vulnerability is in Oracle Enterpr...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: N/A

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-101529

Descripción: Vulnerability in the Oracle Enterprise Manager for Oracle Database product of Oracle Enterprise Manager (component: Data Guard Management). Supported versions that are affected are 13.5 and 24.1. Easily exploitable vulnerability allows low privileged attacker with network access via HTTP to compromise Oracle Enterprise Manager for Oracle Database. While the vulnerability is in Oracle Enterpr...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: N/A

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-81212

Descripción: IBM DataStage on Cloud Pak for Data 5.4.0.0 allows an unauthenticated user to perform an arbitrary write into shared Redis under any tenant's key. This collapses the platform's credential-encryption boundary and lets an anonymous caller poison any tenant's cached flow parameters.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-285

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-87337

Descripción: Vulnerability in the Oracle Access Manager product of Oracle Fusion Middleware (component: Authentication Engine). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.1.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle Access Manager. While the vulnerability is in Oracle Access Manager, attacks may significantly i...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:N

Tipo: N/A

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-87347

Descripción: Vulnerability in the Oracle HTTP Server product of Oracle Fusion Middleware (component: OSSL Module). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows low privileged attacker with network access via HTTP to compromise Oracle HTTP Server. While the vulnerability is in Oracle HTTP Server, attacks may significantly impact additional pro...

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:N

Tipo: N/A

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-91216

Descripción: Vulnerability in the Oracle SOA Suite product of Oracle Fusion Middleware (component: Fabric Layer). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via T3, IIOP to compromise Oracle SOA Suite. While the vulnerability is in Oracle SOA Suite, attacks may significantly impact additional pro...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: N/A

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-91218

Descripción: Vulnerability in the Oracle SOA Suite product of Oracle Fusion Middleware (component: Fabric Layer). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows low privileged attacker with network access via HTTP to compromise Oracle SOA Suite. While the vulnerability is in Oracle SOA Suite, attacks may significantly impact additional products...

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:N

Tipo: N/A

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-91221

Descripción: Vulnerability in the Oracle SOA Suite product of Oracle Fusion Middleware (component: Fabric Layer). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via T3, IIOP to compromise Oracle SOA Suite. While the vulnerability is in Oracle SOA Suite, attacks may significantly impact additional pro...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: N/A

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-91222

Descripción: Vulnerability in the Oracle Business Process Management Suite product of Oracle Fusion Middleware (component: Human Workflow (11g+)). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows low privileged attacker with network access via SOAP to compromise Oracle Business Process Management Suite. While the vulnerability is in Oracle Busine...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: N/A

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-91224

Descripción: Vulnerability in the Oracle SOA Suite product of Oracle Fusion Middleware (component: Fabric Layer). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows low privileged attacker with network access via HTTP to compromise Oracle SOA Suite. While the vulnerability is in Oracle SOA Suite, attacks may significantly impact additional products...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: N/A

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-91225

Descripción: Vulnerability in the Oracle SOA Suite product of Oracle Fusion Middleware (component: Adapters). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle SOA Suite. Successful attacks of this vulnerability can result in unauthorized creation, deletion or modification...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: N/A

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-91230

Descripción: Vulnerability in the Oracle SOA Suite product of Oracle Fusion Middleware (component: Fabric Layer). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle SOA Suite. While the vulnerability is in Oracle SOA Suite, attacks may significantly impact additional product...

CVSS: 9.3 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:L/A:N

Tipo: N/A

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-91231

Descripción: Vulnerability in the Oracle SOA Suite product of Oracle Fusion Middleware (component: Adapters). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle SOA Suite. While the vulnerability is in Oracle SOA Suite, attacks may significantly impact additional products (s...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: N/A

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-91232

Descripción: Vulnerability in the Oracle SOA Suite product of Oracle Fusion Middleware (component: Fabric Layer). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows low privileged attacker with network access via HTTP to compromise Oracle SOA Suite. While the vulnerability is in Oracle SOA Suite, attacks may significantly impact additional products...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: N/A

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-91241

Descripción: Vulnerability in the Oracle Business Intelligence Enterprise Edition product of Oracle Analytics (component: Analytics Web Administration). Supported versions that are affected are 8.2.0.0.0, 12.2.1.4.0 and 26.01.0.0.0. Easily exploitable vulnerability allows high privileged attacker with network access via HTTP to compromise Oracle Business Intelligence Enterprise Edition. While the vulnera...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: N/A

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-91243

Descripción: Vulnerability in the Oracle Business Process Management Suite product of Oracle Fusion Middleware (component: Fabric Layer). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows low privileged attacker with network access via HTTP to compromise Oracle Business Process Management Suite. While the vulnerability is in Oracle Business Proces...

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:N

Tipo: N/A

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-91250

Descripción: Vulnerability in the Oracle SOA Suite product of Oracle Fusion Middleware (component: Adapters). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows low privileged attacker with network access via multiple protocols to compromise Oracle SOA Suite. While the vulnerability is in Oracle SOA Suite, attacks may significantly impact additiona...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: N/A

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-91251

Descripción: Vulnerability in the Oracle SOA Suite product of Oracle Fusion Middleware (component: Adapters). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows low privileged attacker with network access via HTTP to compromise Oracle SOA Suite. While the vulnerability is in Oracle SOA Suite, attacks may significantly impact additional products (sc...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: N/A

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-91341

Descripción: Vulnerability in the Oracle Outside In Technology product of Oracle Fusion Middleware (component: Outside In Clean Content SDK). The supported version that is affected is 8.5.8. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle Outside In Technology. Successful attacks of this vulnerability can result in unauthorized creation,...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: N/A

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-91354

Descripción: Vulnerability in the Oracle Outside In Technology product of Oracle Fusion Middleware (component: Outside In Clean Content SDK). The supported version that is affected is 8.5.8. Easily exploitable vulnerability allows low privileged attacker with network access via HTTP to compromise Oracle Outside In Technology. While the vulnerability is in Oracle Outside In Technology, attacks may signifi...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: N/A

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-91622

Descripción: Vulnerability in the Oracle Agile Product Lifecycle Management for Process product of Oracle Supply Chain (component: Product Quality Management). The supported version that is affected is 6.2.4. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle Agile Product Lifecycle Management for Process. Successful attacks require human in...

CVSS: 9.3 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:N

Tipo: N/A

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-91644

Descripción: Vulnerability in Oracle Essbase (component: Security). The supported version that is affected is 21.8.3.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle Essbase. While the vulnerability is in Oracle Essbase, attacks may significantly impact additional products (scope change). Successful attacks of this vulnerability can ...

CVSS: 9.3 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:L/A:N

Tipo: NVD-CWE-noinfo

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-91655

Descripción: Vulnerability in Oracle Essbase (component: Security). The supported version that is affected is 21.8.3.0.0. Easily exploitable vulnerability allows low privileged attacker with network access via HTTP to compromise Oracle Essbase. While the vulnerability is in Oracle Essbase, attacks may significantly impact additional products (scope change). Successful attacks of this vulnerability can r...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:L/A:L

Tipo: NVD-CWE-noinfo

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-91656

Descripción: Vulnerability in Oracle Essbase (component: Federated Partitions). The supported version that is affected is 21.8.3.0.0. Easily exploitable vulnerability allows low privileged attacker with network access via HTTP to compromise Oracle Essbase. While the vulnerability is in Oracle Essbase, attacks may significantly impact additional products (scope change). Successful attacks of this vulnera...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:L/A:L

Tipo: NVD-CWE-noinfo

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-113736

Descripción: A vulnerability has been found in D-Link DHP-W610AV 1.02EUb03. The impacted element is the function login_prepare_hnap of the file etc/defnodes/defaultvalue.xml of the component HNAP Login. The manipulation of the argument Password leads to empty password in configuration file. The attack can be initiated remotely. The exploit has been disclosed to the public and may be used.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-258

Tecnología: No especificado

Publicado el: 2026-10-21

CVE-2026-114108

Descripción: HKUDS Vibe-Trading from 0.1.0 before 0.1.7 contains a missing authentication vulnerability that allows unauthenticated attackers to access the FastAPI surface because require_auth() returns early when API_AUTH_KEY is unset. Attackers can post messages to /sessions/{id}/messages to trigger root shell commands via BashTool, upload .py or .sh files via /upload, read session histories, and obtain p...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-10-21

CVE-2026-114119

Descripción: Best Practice Software Bp Premier before 1.14.1.1128 uses a hardcoded Microsoft SQL Server administrative password that is shared across all installations and cannot be changed without breaking the application. Attackers with network access to the database instance can authenticate as sysadmin, bypass application authentication, and execute operating system commands as SYSTEM.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-798

Tecnología: No especificado

Publicado el: 2026-10-21

CVE-2026-113744

Descripción: A security vulnerability has been detected in Tenda AC19 16.03.10.07. The impacted element is the function formSetFirewallCfg of the file /goform/SetFirewallCfg of the component httpd Web Management Service. Such manipulation of the argument firewallEn leads to stack-based buffer overflow. The attack may be launched remotely. The exploit has been disclosed publicly and may be used.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-10-21

CVE-2026-109618

Descripción: PHP uses longjmp() for out-of-memory (OOM) errors to exit the current context and abort handling of the request. Some contexts may not properly account for this scenario and leave request memory in an uninitialized state before performing an allocation. The subsequent request cleanup procedure may read or branch on this memory. Multiple OOM strategies can consistently trigger this condition and...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-416

Tecnología: No especificado

Publicado el: 2026-10-21

CVE-2026-114268

Descripción: A flaw has been found in Tenda BE3L Pro 16.03.60.62. Affected by this vulnerability is the function formWifiBasicSet of the file /goform/WifiBasicSet. This manipulation of the argument security_5g causes buffer overflow. It is possible to initiate the attack remotely. The exploit has been published and may be used.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-10-21

CVE-2026-114382

Descripción: A security flaw has been discovered in TOTOLINK EX200 5.2.3c.7200. This affects the function setStaticDhcpConfig of the file /cgi-bin/cstecgi.cgi of the component lan.so. The manipulation of the argument Comment results in stack-based buffer overflow. It is possible to launch the attack remotely. The exploit has been released to the public and may be used for attacks.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-10-21

CVE-2026-114383

Descripción: A weakness has been identified in TOTOLINK EX200 5.2.3c.7200. This impacts the function setWiFiAclAddConfig of the file /cgi-bin/cstecgi.cgi of the component wireless.so. This manipulation of the argument macAddress causes stack-based buffer overflow. The attack can be initiated remotely. The exploit has been made available to the public and could be used for attacks.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-10-21

CVE-2026-114575

Descripción: A flaw has been found in TOTOLINK A950RG 4.1.2cu.5268_B20221104. Affected by this issue is the function UploadCustomModule of the file lib/cste_modules/product.so. Executing a manipulation of the argument FileMd5 can lead to command injection. The attack can be launched remotely. The exploit has been published and may be used.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-10-22

CVE-2021-48016

Descripción: DedeCMS through 5.8.1-beta contains a PHP code injection vulnerability in ShowMsg() where the HTTP Referer header is written into a DedeTemplate string and included. Unauthenticated attackers can send a crafted Referer to /plus/flink.php?dopost=save with an empty validate code to execute arbitrary PHP and system commands. Exploitation evidence was first observed by the Shadowserver Foundation o...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-10-22

CVE-2022-51022

Descripción: YiShaAdmin 2.2 through 3.1, fixed in commit 025b062, contains an unauthenticated path traversal vulnerability in the /admin/File/DownloadFile endpoint that allows attackers to read and delete arbitrary files via the filePath parameter. Attackers can send crafted GET requests with directory traversal sequences in filePath and set the delete parameter to read or remove system files like etc/passw...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:H

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-10-22

CVE-2022-51026

Descripción: Bytebase 0.12.0 before 1.0.1 contains an authentication bypass vulnerability that allows unauthenticated attackers to log in as any user. The flaw stems from trusting client-supplied GitLab provider configuration in the POST /api/auth/login/GITLAB_SELF_HOST endpoint. Attackers can set instanceUrl to a server they control that returns an active user with a chosen email. Bytebase then issues sess...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-290

Tecnología: No especificado

Publicado el: 2026-10-22



CVE-2026-115375

Descripción: Incus 7.0.0 before 7.0.2 and 7.1.0 before 7.5.0 contains a path traversal vulnerability that allows clients able to create instances to write files on the host. The flaw stems from unvalidated dependent custom volume names in instance backup index.yaml files. Attackers can import a crafted instance backup with ../ sequences in dependent volume names to create root-owned directories with control...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-10-22

CVE-2026-115377

Descripción: Incus before 6.0.7, 6.1.0 before 7.0.2, and 7.1.0 before 7.5.0 contains an arbitrary file write vulnerability that allows malicious migration sources to write host files by planting symlinks in transferred volumes. Attackers can craft rsync or btrfs receive streams with a symlink such as rootfs pointing to the host root, writing files as root for full host compromise.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-59

Tecnología: No especificado

Publicado el: 2026-10-22

CVE-2026-115384

Descripción: Wasmtime 39.0.0 before 48.0.4 and 49.0.0 before 49.0.2 contains a stack buffer overflow vulnerability that allows malicious guests to write ~16KB to the native stack via unvalidated async callback result types. Attackers can supply components with mistyped component-model-async callback functions to overwrite return addresses, crashing the host or escaping the sandbox.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-20

Tecnología: No especificado

Publicado el: 2026-10-22

CVE-2026-83938

Descripción: Missing authentication for critical function in Azure Kubernetes Configuration Service allows an unauthorized attacker to elevate privileges over a network.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-10-22

CVE-2026-97785

Descripción: Improper authentication in AAD App Proxy allows an unauthorized attacker to elevate privileges over a network.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-10-22

CVE-2026-115806

Descripción: The Prime Mover – Backup and Migration plugin for WordPress is vulnerable to PHP Object Injection in all versions up to, and including, 2.2.1 via deserialization of untrusted input in the migration search-and-replace routine (recursiveUnserializeReplace()). An unauthenticated attacker can store a crafted, base64-encoded serialized object in wp_comments.comment_content through the standard comme...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-10-24

Resumen del Reporte

CVEs analizados: 57

Promedio CVSS: 9.61

Fuente: nvd.nist.gov

Nos vemos la próxima semana. Hack the Cat

